

Authentication

This document explains how people and machines prove who they are to Meridian: dashboard sign-in, single sign-on (SSO), multi-factor authentication (MFA), personal access tokens, and how to authenticate requests to the REST API.

For managing the API credentials themselves — creating, scoping, rotating, and revoking keys — see [api-keys.md](#).

Overview [auth-01]

There are three ways to authenticate with Meridian, each suited to a different actor:

Actor	Method	Credential
A person, in the dashboard	Email + password, or SSO	Session cookie
A person, from the CLI or scripts	Personal access token	mpat_...
An application or server	API key	msk_... (secret) / mpk_... (publishable)

All authenticated traffic must use HTTPS. Requests over plain HTTP are rejected before they reach your account.

Signing in to the dashboard [auth-02]

Go to <https://dashboard.meridian.io/login> and sign in with:

- **Email and password**, or
- **Google or GitHub** social login, or
- **Your company's SSO** (if an administrator has configured it — see [SSO](#)).

Sessions last **14 days** of inactivity before you are asked to sign in again. You can end all active sessions immediately from **Settings** → **Security** → **Sign out everywhere**, which is the first thing to do if you suspect your account is compromised.

If you forget your password, use **Forgot password?** on the login page. We email a reset link that is valid for **60 minutes** and can be used once.

Multi-factor authentication (MFA) [auth-03]

Meridian strongly recommends enabling MFA on every account, and organization administrators can **require** it for all members (see [account-management.md](#)).

Supported second factors:

- **Authenticator app (TOTP)** — any RFC 6238 app such as 1Password, Authy, or Google Authenticator.
- **Security keys / passkeys (WebAuthn)** — hardware keys (YubiKey) or platform authenticators (Touch ID, Windows Hello).

To enable MFA: **Settings** → **Security** → **Two-factor authentication** → **Add method**. When you enable TOTP, save the **recovery codes** we show you. Each recovery code works once and lets you sign in if you lose your device. If you lose both your device and your recovery codes, contact support@meridian.io to begin identity verification; recovery can take up to **3 business days** and is intentionally strict.

***Note:** MFA protects dashboard and CLI sign-in. It does **not** apply to API keys — a leaked secret key grants access regardless of MFA, which is why key rotation and scoping matter. See [api-keys.md](#).*

Single sign-on (SSO) [auth-04]

SSO is available on the **Team** and **Enterprise** plans. Meridian supports:

- **SAML 2.0** with any compliant identity provider (Okta, Microsoft Entra ID, Google Workspace, JumpCloud).
- **SCIM 2.0** provisioning (Enterprise) to automatically create, update, and deactivate members when they join or leave in your IdP.

To configure SAML SSO:

1. Go to **Settings** → **Security** → **SSO** and note the **ACS URL** and **Entity ID** shown there. 2. Create a SAML application in your identity provider using those values. 3. Paste your IdP's **metadata URL** (or upload the metadata XML) back into Meridian. 4. Verify your domain by adding the TXT record we provide. Domain verification prevents anyone else from claiming your company's email domain. 5. Optionally enable **Require SSO**, which forces every member whose email matches the verified domain to sign in through your IdP and disables password login for them.

When **Require SSO** is on, existing password and social logins for matching members are disabled at their next sign-in. Break-glass access for administrators is preserved through a dedicated recovery flow documented in [account-management.md](#).

Authenticating API requests [auth-05]

The REST API uses **bearer authentication**. Send your secret API key in the **Authorization** header:

```
curl https://api.meridian.io/v1/services \
-H "Authorization: Bearer msk_live_XXXXXXXXXXXXXXXXXXXX"
```

Rules that always apply:

- **Secret keys** (`msk_live_...` , `msk_test_...`) authenticate server-side requests and must never be exposed in browsers, mobile apps, or public repositories.
- **Publishable keys** (`mpk_live_...`) identify your account in front-end contexts and can only perform a small set of safe, read-mostly operations.
- A missing or malformed header returns `401` with error code `missing_authorization` . An invalid or revoked key returns `401` with `invalid_api_key` . A well-formed key that lacks permission for the operation returns `403` with `insufficient_scope` . See [errors.md](#).

Meridian does **not** support basic auth, query-string keys (`?api_key=...`), or cookies for the REST API. Keys must be sent in the header on every request.

Personal access tokens [auth-06]

A **personal access token (PAT)** authenticates *you* — not an organization service account — from the CLI, scripts, or CI. Tokens start with `mpat_` and inherit your own role and permissions.

- `meridian login` creates one automatically and stores it in `~/.meridian/config.json` .
- To create one manually: **Settings** → **Personal access tokens** → **Generate token**. Choose an expiry (**30, 60, 90 days, or no expiry**) and copy the value — it is shown only once.
- PATs are ideal for personal automation and local development. For shared, production, or CI use, prefer an **organization API key** so access does not break when a person leaves the company.

Revoke a PAT any time from the same page; revocation takes effect within a few seconds across all regions.

OAuth for third-party apps [auth-07]

If you are building an application that acts on behalf of *other* Meridian users (for example, a deployment dashboard or a Slack integration), use **OAuth 2.0** instead of asking users for their API keys.

- Register an OAuth app under **Settings** → **OAuth apps** to get a `client_id` and `client_secret` .
- Meridian supports the **authorization code** grant with **PKCE**.
- Authorization endpoint: `https://dashboard.meridian.io/oauth/authorize` .
- Token endpoint: `https://api.meridian.io/v1/oauth/token` .
- Request only the **scopes** you need (for example `services:read deployments:write`). Users see and approve the exact scopes on the consent screen.

Access tokens are short-lived (**1 hour**); use the returned **refresh token** to obtain new ones. Never ask a user to paste their secret key into your product — that is what OAuth exists to prevent.

Choosing the right method [auth-08]

You are...	Use
A developer clicking around the dashboard	Email/password or SSO + MFA
Running deploy commands locally	Personal access token (via <code>meridian login</code>)
A backend service calling the API	Organization secret API key
Front-end code that must identify the account	Publishable key (never a secret key)
Building an app for other Meridian users	OAuth 2.0

Frequently asked questions [auth-09]

Can I use an API key to sign in to the dashboard? No. The dashboard uses password or SSO sign-in; API keys authenticate only the REST API. See [Signing in](#) and [Authenticating API requests](#).

Does MFA protect my API keys? No. MFA protects human sign-in (dashboard and CLI). A leaked secret key works regardless of MFA, which is why scoping and rotation matter. See [api-keys.md](#).

****I lost my MFA device *and* my recovery codes. What now? Contact support@meridian.io to begin identity verification. Recovery is intentionally strict and can take up to 3 business days**. Store recovery codes offline to avoid this.**

Can a member use both a password and SSO? If an admin has enabled **Require SSO** for your verified domain, password and social login are disabled for matching members and they must sign in through your IdP. See [SSO](#).

How long does a dashboard session last? 14 days of inactivity, after which you're asked to sign in again. You can end all sessions immediately with **Sign out everywhere**.

Should CI use a personal access token or an API key? An **organization API key** — it doesn't break when a person leaves. PATs are for personal, local use. See [Personal access tokens](#).

Related documents

- [api-keys.md](#) — create, scope, rotate, and revoke API keys.
- [security.md](#) — how Meridian protects credentials and data.
- [account-management.md](#) — roles, permissions, and enforcing MFA/SSO.
- [errors.md](#) — the full list of authentication error codes.